

Performing a Risk Assessment (3e)

Managing Risk in Information Systems, Third Edition - Lab 04

Student:

Dquez Carr

Email:

dquezcarr@gmail.com

Time on Task:

31 hours, 36 minutes

Progress:

88%

Report Generated: Monday, April 6, 2026 at 11:50 PM

Guided Exercises

Part 1: Prepare for a Risk Assessment

- Given the scenario provided above, **identify** the level of the risk assessment you will perform. Your risk assessment may cover multiple tiers.

The level of the risk assessment I will be performing is on all tiers.

- For three of the five vulnerabilities identified in the scenario provided above, **identify** the Tier that would best address the vulnerability and provide your justification.

Acme has not been regularly monitoring and testing its IT infrastructure is a tier 3 issue because it directly impacts systems and security controls, not strategy or business processes. The policy password is a tier 1 issue because policies are set at the organizational governance level. Critical vulnerabilities exist on servers due to lack of patch management procedures is a tier 2 issue because patch management is a business/security process, not just a single system issue.

- Describe** the purpose of this risk assessment.

The purpose of this risk assessment is to identify and evaluate threats, vulnerabilities, and their potential impacts within the organization so management can make informed decisions about how to handle risk. It is intended to produce information on security weaknesses, likelihood and impact, and recommended mitigation actions that support decisions such as accepting, mitigating, transferring, or avoiding risk. Overall, the assessment helps leadership prioritize remediation, allocate resources, strengthen policies and processes, and improve the organization's overall security posture.

9. **Describe** the scope of this risk assessment.

The risk assessment covers the organization's IT systems, processes, and employees handling sensitive data. It applies across policies, processes, and technical systems, and remains valid short term but should be updated with major changes or new threats.

11. **Identify** the assumptions and constraints associated with this risk assessment.

The risk assessment assumes that weak user account management, such as test accounts, inactive accounts, and lack of account ownership, increases the risk of unauthorized access to a production server, and that standard account management controls should be in place. It also assumes the server supports important business functions, so compromise would have a significant impact. Constraints include limited accountability, possible resource or staffing gaps, and operational needs that may delay immediate remediation in the production environment.

13. **Identify** the information sources associated with this risk assessment.

The risk assessment assumes that weak user account management, such as test accounts, inactive accounts, and lack of account ownership, increases the risk of unauthorized access to a production server, and that standard account management controls should be in place. It also assumes the server supports important business functions, so compromise would have a significant impact. Constraints include limited accountability, possible resource or staffing gaps, and operational needs that may delay immediate remediation in the production environment.

21. Based on the information provided above, **define** your assessment approach as quantitative, qualitative, or semi-quantitative and **provide** your justification.

This risk assessment is qualitative because it uses descriptive ratings such as likely or unlikely for likelihood and minor or major for impact instead of exact numbers. A qualitative approach relies on judgment and severity categories to describe risk, while a quantitative approach would use numerical probabilities and measurable loss values.

Part 2: Conduct a NIST SP 800-30 Risk Assessment

2. Think about the sort of adversarial agent that could exploit the vulnerability summarized above. **Identify** one threat source according to Table D-2 on Page D-2 of the NIST SP800-30 document.

A relevant threat source for this vulnerability is an adversarial outsider. Because Acme is not regularly monitoring or testing its IT infrastructure, an external attacker could exploit security weaknesses, gain access, and remain undetected for a longer period of time. This makes an outsider a strong example of a threat source under Table D-2 of NIST SP 800-30.

3. For the selected threat, **identify** its capability, intent, and targeting, according to Table D-3, Table D-4, and Table D-5, respectively.

For the adversarial outsider threat, the capability is moderate to high because the attacker may have the skills and tools needed to identify and exploit weaknesses in an environment that is not being regularly monitored or tested. The intent is malicious, as the goal would be unauthorized access, disruption, or data theft. The targeting is opportunistic, since the attacker is likely to look for any vulnerable system and take advantage of Acme's weak security posture.

4. For the selected threat, **identify** specific threat event(s) according to Table E-2.

For the adversarial outsider threat, a relevant threat event is unauthorized access to the system through exploitation of unmonitored vulnerabilities. Because Acme is not regularly monitoring or testing its infrastructure, an attacker could scan for weaknesses, exploit a vulnerability, gain initial access, and maintain persistence without detection. Additional related threat events include execution of malicious code, privilege escalation, and data exfiltration, all enabled by the lack of monitoring controls.

5. **Identify** the vulnerability and **determine** the vulnerability severity, according to Table F-2.

The vulnerability is Acme's failure to regularly monitor and test its IT infrastructure, which leaves security weaknesses unidentified and reduces the organization's ability to detect attacks in a timely manner. Based on Table F-2, this vulnerability would be considered high severity because it greatly increases the chance that threats can exploit the environment and remain undetected, leading to serious potential impact.

6. **Identify** the *Likelihood of threat event initiation* and *Likelihood of threat event resulting in adverse impacts* values, according to Table G-2 and Table G-4, respectively.

The likelihood of threat event initiation is likely, because adversarial outsiders commonly scan for and exploit systems that lack monitoring and testing, making Acme an attractive target. The likelihood of the threat event resulting in adverse impacts is also likely, since the absence of monitoring increases the chance that an attacker can remain undetected, escalate access, and cause damage such as data loss or system compromise.

7. **Identify** the overall likelihood value, which you will later use in SimpleRisk, according to Table G-5.

The likelihood is likely.

8. **Identify** the potential adverse impacts, according to Table H-2.

The potential adverse impacts include unauthorized access to sensitive data, leading to loss of confidentiality, as well as possible modification or destruction of data, impacting integrity. There may also be system disruption or downtime, affecting availability of services. Additionally, the organization could face financial loss, reputational damage, and potential regulatory or legal consequences if sensitive information is compromised.

9. **Identify** the impact value, which you will later use in SimpleRisk, according to Table H-3.

The impact value is high.

Part 3: Use SimpleRisk to Track and Calculate Risk

Performing a Risk Assessment (3e)

Managing Risk in Information Systems, Third Edition - Lab 04

8. Make a screen capture showing the submitted risk in SimpleRisk.

The screenshot displays the SimpleRisk Enterprise Risk Management web application. The browser window title is "SimpleRisk: Enterprise Risk Man". The address bar shows a "Not secure" connection to "https://172.30.0.5/management/index.php". The page content is organized into two columns of form fields. The left column includes fields for Risk Mapping, Submission Date (04/06/2026), Category, Site/Location, External Reference ID, Control Regulation (PCI DSS v3.2), Control Number, Affected Assets, Technology, Team, Additional, Stakeholders, Owner, and Owner's Manager. The right column includes Submitted By (Admin), Risk Source (Process), Risk Scoring Method (Classic), Current Likelihood (Likely), Current Impact (Major), Risk Assessment (a text area containing "The Capability, intent, and targeting values you identified in Part 2, Step 3" and "The Relevance value you identified in Part 2, Step 4"), Additional Notes, and Supporting Documentation (None). A "Tags" section is visible at the bottom left of the form area. The Windows taskbar at the bottom shows the time as 8:30 PM on 4/6/2026.

Risk Mapping:	Submitted By: Admin
Submission Date: 04/06/2026	Risk Source: Process
Category:	Risk Scoring Method: Classic
Site/Location:	Current Likelihood: Likely
External Reference ID:	Current Impact: Major
Control Regulation: PCI DSS v3.2	Risk Assessment: The Capability, intent, and targeting values you identified in Part 2, Step 3 The Relevance value you identified in Part 2, Step 4
Control Number:	Additional Notes:
Affected Assets:	Supporting Documentation: None
Technology:	
Team:	
Additional:	
Stakeholders:	
Owner:	
Owner's Manager:	

Tags

Challenge Exercise

Make a screenshot showing the **submitted risk for Target in SimpleRisk**.

Incomplete

Explain your choices and thought process.

Incomplete